

NETWORK & INFORMATION SECURITY

Chapter 4 — Network Security

Comprehensive Short Notes for ESE

K.J. Somaiya College of Engineering | B.Tech Computer Engineering | Sem VI

Topics Covered (based on ESE 2023, 2024, 2025 papers):

- 1. Network Security Principles & CIA Triad
- 2. Network Security Protocols (SSL/TLS, HTTPS, IPSec)
- 3. Threats to Network Communications (Interception, Interruption, Modification, Fabrication)
- 4. Network-Based Attacks (DoS/DDoS, MitM, DNS Spoofing, IP Spoofing)
- 5. Authentication Mechanisms & Access Control Models
- 6. Firewalls (Types, IDS, IPS, NGFW)
- 7. VPN & Wi-Fi Security (WPA/WPA2)
- 8. Securing Communication

1. Network Security Principles

The CIA Triad + Extended Principles

Principle	Definition	Attacked By
Confidentiality	Only authorized users can access data	Interception, Eavesdropping
Integrity	Data cannot be altered without authorization	Modification, MitM
Availability	Systems/resources remain accessible	DoS/DDoS, Interruption
Authentication	Verifying identity of users/devices	Fabrication, Spoofing
Authorization / Access Control	Limiting access based on roles/permissions	Privilege Escalation
Non-repudiation	Parties cannot deny their actions	Identity Fraud
Zero Trust Model	"Never trust, always verify" — every request authenticated	Insider Threats

★ **EXAM TIP:** CIA Triad questions are asked EVERY year. Map each attack type to the CIA element it violates.

2. Threats to Network Communications

There are four main categories of threats to network communications:

Attack	Characteristics	Examples	CIA Impact	Type
Interception	Unauthorized access to data in transit	Eavesdropping, Packet sniffing, MITM	Confidentiality	Passive
Interruption	Disrupts or destroys a service/asset	DoS, Malware, Hardware disruption	Availability	Active
Modification	Gains access AND tampers with content	MITM, Cross-Site Scripting (XSS)	Integrity + Availability	Active
Fabrication	Inserts bogus/fake data into system	Spoofing, SQL Injection, Phishing, Replay	Authentication + Availability	Active

2.1 Interception

Definition: Unauthorized access to data shared between two parties.

Examples: Packet sniffing, Man-in-the-Middle (MITM), Eavesdropping, Password attacks

CIA Impact: Confidentiality

Mitigation:

- Encrypt all communications (SSL/TLS)
- Avoid untrusted Wi-Fi networks
- Regularly update software, OS and passwords

2.2 Interruption

Definition: A network service or asset is disrupted/destroyed, preventing legitimate access.

Examples: DoS attack, Malware (viruses/trojans), Hardware/software damage

CIA Impact: Availability

Mitigation:

- Firewalls and intrusion prevention systems
- Regular system backups
- Cloud-based solutions and CDN (Content Delivery Networks)

2.3 Modification

Definition: Attacker gains access AND manipulates/alters the data.

Examples: MITM attack (intercepts and modifies), Cross-Site Scripting (XSS) — injects malicious script into a web app

CIA Impact: Integrity (primary) + Availability (secondary — if config file is modified, service may fail)

Mitigation:

- Intrusion Detection Systems (IDS)
- Data Encryption
- Access Controls

2.4 Fabrication

Definition: Intruder injects bogus data or creates a false trail in the system.

Examples: Identity spoofing, SQL Injection, Phishing attacks, Replay attacks

CIA Impact: Authentication (primary) + Availability (e.g., traffic injection can block a service)

Mitigation:

- Digital signatures
- Data encryption
- Firewalls

★ **EXAM TIP:** Q2023: 'Hacker copies files, defaces web page, steals credit card numbers' → INTERCEPTION (copying files), MODIFICATION (defacing page), INTERCEPTION (stealing CC numbers). Interception = passive, rest = active.

3. Network Security Protocols

3.1 SSL/TLS (Secure Sockets Layer / Transport Layer Security)

Purpose: Secures web traffic (HTTPS) and encrypts data transmission between client and server.

Layer of Operation: Between Transport Layer (TCP) and Application Layer

Note: SSL was predecessor; TLS is the modern standard. Often called SSL/TLS collectively.

SSL/TLS Architecture (3 Sub-Protocols)

Protocol	Role
Handshake Protocol	Authentication + negotiation of encryption algorithms and keys BEFORE data transfer
Record Protocol	Takes data → fragments → compresses → adds MAC → encrypts → transmits
Alert Protocol	Handles errors and connection closures

SSL/TLS Handshake Workflow (Step-by-Step)

Step 1 — Client Hello:

- Client sends: supported TLS versions + cipher suites

Step 2 — Server Hello & Certificate:

- Server selects algorithms, sends its digital certificate (containing public key) + "Server Hello Done"

Step 3 — Key Exchange:

- Client verifies certificate, generates pre-master secret, encrypts with server's public key, sends it

Step 4 — Session Key Generation:

- Both parties independently generate symmetric session keys from the pre-master secret

Step 5 — Finished:

- Both send "finished" message → all subsequent data is encrypted with session keys

3.2 HTTPS (HyperText Transfer Protocol Secure)

Definition: HTTPS is NOT a separate protocol. It is HTTP running on top of an SSL/TLS encrypted connection.

Formula: **HTTPS = HTTP + SSL/TLS**

Layer: Application Layer

Port: 443 (HTTP uses port 80)

Certificate Authority (CA): Issues digital certificates to verify server identity

HTTPS Workflow

- Step 1 — Connection Request: Client requests `https://example.com`

- Step 2 — TLS Handshake: Browser and server verify certificate and establish session keys
- Step 3 — Secure Transmission: All HTTP data encrypted by TLS Record Protocol and sent securely

3.3 IPsec (Internet Protocol Security)

Definition: Suite of protocols that secures IP communications by authenticating and encrypting each IP packet.

Layer: Network Layer (Layer 3)

Used for: VPNs — encrypts traffic between two network gateways

IPsec Architecture Components

Component	Function
Authentication Header (AH)	Provides data integrity and authentication — NO encryption
Encapsulating Security Payload (ESP)	Provides confidentiality (encryption) + authentication + integrity
Security Association (SA)	Establishes shared security parameters (keys, algorithms) between peers
Internet Key Exchange (IKE)	Manages key exchange and negotiates Security Associations

IPsec Modes of Operation

Mode	What is Encrypted	Use Case
Transport Mode	Only the IP payload (data) — header is NOT encrypted	End-to-end communication between two hosts
Tunnel Mode	Entire IP packet (header + payload) — wrapped in new IP packet	VPNs between two gateways

IPsec Workflow

- IKE Phase 1: Peers negotiate security policies and establish a secure IKE channel
- IKE Phase 2: Using secure channel, peers negotiate IPsec SAs (ESP or AH) for actual data
- Data Transmission: Data is encapsulated (ESP/AH), encrypted and transmitted
- Termination: IPsec tunnel closes when transfer is done or SA expires

3.4 Other Key Security Protocols

Protocol	Full Form	Purpose	Port
SSH	Secure Shell	Secure command-line access to remote servers	22
SFTP	Secure File Transfer Protocol	Transfers files securely over SSH	22
SNMP	Simple Network Management Protocol	Manages/monitors network devices securely	161/162
ICMP	Internet Control Message Protocol	Diagnostics (ping, traceroute) — must be secured against exploits	N/A

★ **EXAM TIP:** *SSL/TLS workflow (5 steps) is frequently asked. Remember: Client Hello → Server Hello+Cert → Key Exchange → Session Key → Finished. HTTPS = HTTP + SSL/TLS on port 443.*

4. Network-Based Attacks

4.1 Denial-of-Service (DoS) Attack

Definition: Malicious attempt to degrade server performance or disrupt availability by overwhelming it with requests.

How it works: Floods target with requests → exhausts system resources → service becomes unavailable

CIA Impact: Availability

Types of DoS Attacks

Type	Sub-types	How it works
Volumetric Attacks (Bandwidth Floods)	UDP Flood, ICMP (Ping) Flood	Saturates network bandwidth. UDP: sends massive UDP packets to random ports. ICMP: overwhelms with ping requests.
Protocol Attacks (State-Table Exhaustion)	SYN Flood, Ping of Death, Smurf Attack	Consumes server/firewall resources. SYN Flood: sends SYN but never ACK → half-open connections exhaust table.
Application-Layer Attacks (Layer 7)	HTTP Flood, Slowloris, R.U.D.Y.	Targets specific app vulnerabilities. Slowloris: holds many connections open with partial HTTP requests.

4.2 DoS vs. DDoS — Key Differences

Criteria	DoS Attack	DDoS Attack
Source	Single machine/IP	Multiple machines (botnets, compromised IPs)
Complexity	Simple to execute	Complex — requires coordination
Traffic Volume	Lower volume	Significantly higher volume
Detection	Easier to detect	Harder to detect and mitigate
Impact	Limited impact	Severe — can overwhelm even large systems

4.3 Man-in-the-Middle (MitM) Attack

Definition: Attacker secretly intercepts and relays communications between two parties to steal or manipulate data.

Also called: On-path attack / Adversary-in-the-Middle attack

What attacker steals: Login credentials, credit card numbers, session tokens, sensitive communications

CIA Impact: Confidentiality + Integrity

Types of MitM Attacks

Type	How it works
ARP Spoofing	Links attacker's MAC address with a legitimate IP → intercepts all traffic on local network
DNS Spoofing	Modifies DNS records → users directed to fraudulent/fake website instead of real one
HTTPS/SSL Stripping	Downgrades secure HTTPS connection to unencrypted HTTP → attacker reads all data
Evil Twin Wi-Fi	Creates a fake Wi-Fi hotspot identical to legitimate one → steals data from users who connect

Best Practices to Prevent MitM (asked in 2023, 2025 ESE)

- Always use HTTPS websites (look for padlock icon)
- Use a VPN, especially on public Wi-Fi
- Enable HSTS (HTTP Strict Transport Security) on servers
- Use certificate pinning in mobile apps
- Enable Multi-Factor Authentication (MFA)
- Avoid connecting to unknown/unverified Wi-Fi networks

4.4 DNS Spoofing / DNS Poisoning

How it works:

- Step 1: User requests a website → query goes to DNS server
- Step 2: Attacker exploits flaws in DNS server → injects fake/malicious DNS record
- Step 3: DNS server returns fake IP → user is redirected to attacker's fake website

Result: User lands on a fake site (looks real) → credentials/data stolen

Prevention: DNSSEC (DNS Security Extensions), use trusted resolvers

4.5 Other Key Network-Based Attacks

Attack	Description
Packet Sniffing	Capturing data packets as they travel through the network to steal credentials. Mitigate: use encryption (TLS/VPN).
IP Spoofing	Creating packets with a fake source IP address to impersonate a trusted host. Used in DDoS amplification.
SQL Injection (SQLi)	Inserting malicious SQL code into input fields to query or alter databases. Mitigate: input validation, prepared statements.
Malware/Ransomware	Viruses, worms, and ransomware spread across networks to damage or lock data.
Port Scanning	Probing open ports on a host to discover vulnerabilities. Tools: Nmap. Used in reconnaissance phase.

★ **EXAM TIP:** Asked in 2025 ESE: IP Spoofing, Packet sniffing, Port scanning. DoS vs DDoS comparison asked in 2023 & 2024. MitM prevention practices asked in 2023 ('compare AES and DES' appears in same paper as MitM best practices).

5. Authentication Mechanisms

Definition: Authentication mechanisms verify the identity of users/devices to secure access to systems.

Three Factors of Authentication:

- Something you **KNOW** — passwords, PINs, security questions
- Something you **HAVE** — OTP token, smart card, phone
- Something you **ARE** — biometrics (fingerprint, face, retina)

Method	Description	Example
Password-Based	Knowledge-based — user must know a secret string	Login passwords, PINs
Biometrics	Biological traits unique to each person	Fingerprint scanner, facial recognition, retina scan
Two-Factor Auth (2FA)	Requires TWO different factors for access	Password + OTP (Google Authenticator)
Multi-Factor Auth (MFA)	Two or more factors required	Bank ATM: card (HAVE) + PIN (KNOW)
Certificate-Based	Uses digital certificates issued by CA	HTTPS, SSH key pairs
Token-Based	Physical/software-generated one-time codes	RSA SecurID, TOTP apps

6. Access Control Models

Definition: Access control models define HOW systems identify, authenticate, and authorize users to protect resources.

Model	Full Name	Who controls access?	Mechanism	Use Case
DAC	Discretionary Access Control	Resource OWNER decides	Owner sets permissions for each file/resource	File systems, small offices
MAC	Mandatory Access Control	Central AUTHORITY enforces	Security labels & clearance levels (e.g., Top Secret)	Government, military, classified systems
RBAC	Role-Based Access Control	ROLES determine permissions	Permissions assigned to job roles (Admin, User, Manager)	Large organizations, enterprise systems
ABAC	Attribute-Based Access Control	Dynamic POLICY decides	Uses user, resource, AND environment attributes (time, location)	Cloud systems, fine-grained control
RuBAC	Rule-Based Access Control	RULES in ACL decide	Predefined rules (e.g., only allow access 9am–5pm)	Network devices, firewalls

DAC vs MAC — Quick Comparison (asked in 2025 ESE)

Feature	DAC	MAC
Access set by	Owner of the resource	Central authority / system admin
Flexibility	High (flexible)	Low (rigid, policy-driven)
Security level	Lower	Higher
Use case	Home, small offices	Military, government
User control	Users can grant others access	Users cannot change permissions

★ **EXAM TIP:** Access control questions appear in Q1 (short) and Q5 (short notes). Know all 5 types: DAC, MAC, RBAC, ABAC, RuBAC with one-line definitions. 2025 asked: MAC vs DAC difference.

7. Firewalls

Definition: A firewall is a security barrier between internal systems and external networks. It forces all traffic through a checkpoint where packets are monitored, filtered, and allowed or blocked based on predefined rules.

Analogy: Like a security guard at a building entrance — checks everyone before allowing entry.

7.1 Why Firewalls Are Important

- Prevent Unauthorized Access — only trusted traffic passes through
- Block Malicious Traffic — stops viruses, phishing, DoS attacks at the perimeter
- Protect Sensitive Information — safeguards personal and business data
- Control Network Usage — enforces policies (parental controls, workplace restrictions)
- Mitigate Insider Risks — detects suspicious outbound traffic / data exfiltration

7.2 Types of Firewalls (by Processing Mode)

Type	How it works	Pros	Cons
Packet Filtering Firewall	Inspects IP/TCP headers (source/dest IP, port, protocol). Allows or blocks based on ACL rules.	Fast, low overhead, simple	Cannot inspect payload; stateless
Stateful Inspection Firewall	Tracks active connections in a state table. Knows if packet is part of established session.	Better security than packet filtering	Slower; more resource-intensive
Proxy (Application) Firewall	Acts as intermediary between client and server. Terminates connection and re-initiates it.	Deep inspection of content; hides internal IPs	Slow; application-specific
Next-Generation Firewall (NGFW)	All above + DPI + IPS + App awareness + SSL decryption + Threat Intelligence	Comprehensive; can detect modern attacks	Expensive; complex to configure
Cloud Firewall (FWaaS)	Firewall delivered as a cloud service	Scalable, no hardware needed	Dependent on internet connectivity

7.3 Next-Generation Firewall (NGFW) — Key Features

NGFW vs Traditional Firewall: Traditional firewalls operate at Layers 3-4 (IP addresses and ports). NGFW operates at ALL layers including Layer 7 (Application Layer).

Key Features of NGFW:

- Application Awareness & Control — identifies/controls apps regardless of port (can block BitTorrent even on port 80)
- Intrusion Prevention System (IPS) — scans traffic for malicious patterns, automatically blocks threats
- Deep Packet Inspection (DPI) — analyzes packet CONTENT (not just headers) to detect hidden malware
- Threat Intelligence Integration — uses live threat feeds to identify malicious IPs
- SSL/TLS Decryption — inspects encrypted traffic for hidden threats
- User Identification — creates policies based on users/groups (not just IPs)

7.4 Intrusion Detection System (IDS)

Definition: Hardware or software that analyzes network traffic for malicious activities or policy violations and issues ALERTS.

Key Point: **IDS is NOT in the data path — it can only DETECT and ALERT, NOT block.**

Placement: Connected to a SPAN/mirror port on the switch — receives a copy of traffic

Detection Methods:

- Signature-Based: Matches traffic against known attack signatures
- Anomaly-Based: Detects deviations from normal baseline behavior

7.5 Intrusion Prevention System (IPS)

Definition: Device that inspects, detects, classifies and PROACTIVELY PREVENTS harmful traffic.

Key Point: **IPS IS in the data path (inline mode) — it can BLOCK attacks in real-time.**

Placement: Layer 2, inline after the firewall — traffic flows through it

Actions IPS can take:

- Alert network administrators
- Drop the malicious packet/traffic
- Deny traffic from the source address (block IP)
- Reset the TCP connection

IDS vs. IPS — Key Difference

Feature	IDS	IPS
Position in network	Out of band (mirror port)	Inline (in data path)
Can block traffic?	NO — alerts only	YES — can block in real-time
Response to threats	Passive — sends alerts	Active — drops packets, blocks IPs
Impact on network	No impact (passive)	Adds latency (inline)
Risk of false positives	Low risk (no blocking)	High risk — may block legitimate traffic

★ **EXAM TIP:** Firewalls are VERY frequently asked. Know: types of firewalls (by processing mode), IDS vs IPS key difference (IDS = detect only, IPS = detect + prevent/block), and NGFW additional features over traditional firewall.

8. VPN (Virtual Private Network)

Definition: VPN creates a secure, encrypted tunnel between your device and the internet, protecting data from hackers/surveillance while masking your IP address.

8.1 How VPNs Work

Mechanism	Explanation
Encryption	Converts data into unreadable ciphertext. Only your device and VPN server hold the decryption key.
Tunneling	Routes your traffic through a secure VPN server, hiding activity from ISP/hackers. Uses IPSec or OpenVPN protocols.
IP Masking	Replaces your real IP with VPN server's IP, concealing your physical location and identity.

8.2 VPN Benefits and Use Cases

- Public Wi-Fi Security — encrypts traffic on untrusted/public hotspots
- Remote Work — employees securely access company internal resources from home
- Streaming & Privacy — bypass geographic content restrictions, hide browsing history
- Site-to-Site VPN — connects two company office networks securely over the internet
- Used with IPSec Tunnel Mode — entire IP packet encrypted between gateways

Why is firewall a good place to implement a VPN? (asked in 2024 ESE)

- The firewall is already the network perimeter point where all traffic enters/exits
- Combined firewall+VPN checks VPN authentication AND applies firewall rules simultaneously
- Reduces complexity — single security appliance handles both perimeter security and VPN termination
- Better access control — VPN clients are authenticated before being allowed into the internal network
- Centralized logging and monitoring of all remote access traffic

9. Wi-Fi Security — WPA/WPA2

Standard	Year	Encryption	Notes
WEP (Wired Equivalent Privacy)	1997	RC4 (40-bit key)	BROKEN — easily cracked. Multiple known vulnerabilities.
WPA (Wi-Fi Protected Access)	2003	TKIP (Temporal Key Integrity Protocol)	Transitional fix; stronger than WEP but still had vulnerabilities.
WPA2 (IEEE 802.11i)	2004	AES (CCMP) — 128-bit	Current standard. Strong encryption. Personal (PSK) and Enterprise (802.1X) modes.

Standard	Year	Encryption	Notes
WPA3	2018	SAE (Simultaneous Authentication of Equals)	Latest standard. Forward secrecy. Resistant to offline dictionary attacks.

WEP Weaknesses (frequently asked)

- Short IV (Initialization Vector) — only 24 bits, leads to IV reuse → key can be derived
- No replay protection — old packets can be resent
- Weak key scheduling in RC4 algorithm
- No protection against forgery — integrity check (CRC-32) can be manipulated
- No mutual authentication — anyone can impersonate an access point

★ **EXAM TIP:** WEP weaknesses asked in 2024 ESE (Q1-v). Remember: IV reuse, no replay protection, weak RC4 scheduling. WPA2 = IEEE 802.11i = AES-CCMP.

10. Quick Revision — All Topics

10.1 Attack Quick Reference

Attack	CIA Violated	Active/Passive	Example	Mitigation
Interception	Confidentiality	Passive	Packet Sniffing, Eavesdropping	TLS Encryption, VPN
Interruption	Availability	Active	DoS, DDoS, Malware	Firewall, CDN, Backups
Modification	Integrity	Active	MITM, XSS	IDS, Encryption, Access Controls
Fabrication	Authentication	Active	Spoofing, Phishing, SQL Injection	Digital Signatures, Firewalls
DoS	Availability	Active	SYN Flood, UDP Flood	Rate Limiting, IPS
DDoS	Availability	Active	Botnet Flood	CDN, Anti-DDoS services
MITM	Conf + Integrity	Active	ARP Spoofing, SSL Strip	HTTPS, MFA, VPN
DNS Spoofing	Integrity	Active	Fake DNS record injection	DNSSEC

10.2 Protocol Quick Reference

Protocol	Layer	Purpose	Key Feature
SSL/TLS	Transport→Application	Encrypt web/app traffic	Handshake → session key → encrypted channel
HTTPS	Application	Secure web browsing	HTTP + TLS, port 443, uses CA certificate
IPSec	Network (L3)	Secure IP communications, VPNs	AH (auth), ESP (encrypt), Transport/Tunnel modes
SSH	Application	Secure remote shell access	Encrypted command line, port 22
VPN	Network	Secure private tunnel over public internet	Encryption + tunneling + IP masking

10.3 Firewall Types Quick Reference

Firewall Type	Inspects	Can detect App-layer?	Can block in real-time?
Packet Filtering	IP/TCP headers only	No	Yes (based on IP/port rules)
Stateful Inspection	Headers + connection state	No	Yes
Application/Proxy	Full application content	Yes	Yes
NGFW	Everything incl. payload + user identity	Yes (advanced)	Yes + can decrypt TLS
IDS	Traffic patterns (signatures/anomaly)	Yes	NO — alerts only

Firewall Type	Inspects	Can detect App-layer?	Can block in real-time?
IPS	Traffic patterns (inline)	Yes	YES — blocks in real-time

10.4 Must-Know Short Notes Topics (from ESE Papers)

These topics appeared as short notes in Q5 across 2023–2025:

Topic	Key Points to Remember	Year Asked
Digital Signatures	Uses asymmetric crypto. Sign with private key, verify with public key. Provides authentication + non-repudiation.	2024
Ransomware	Malware that encrypts victim's files. Attacker demands ransom for decryption key. Prevention: backups, patch management.	2024
Authentication mechanisms	Something you know, have, are. 2FA = two factors. MFA = multiple factors.	2024
Link vs End-to-End Encryption	Link: encrypted only on each link, decrypted at each node. E2E: encrypted at source, decrypted only at final destination.	2023, 2025
DMZ (Demilitarized Zone)	Network segment between internal and external network. Contains public-facing servers (web, email, DNS). Protected by two firewalls.	2024, 2025
OWASP	Open Web Application Security Project. Maintains Top 10 list of web vulnerabilities: SQLi, XSS, Broken Auth, etc.	2023, 2025
Public Key Cryptography	Asymmetric: public key encrypts, private key decrypts. E.g., RSA. Used in SSL/TLS handshake, digital signatures.	2025
Replay Attack	Attacker captures a valid data transmission and retransmits it. Prevention: timestamps, nonces, sequence numbers.	2024, 2025

10.5 Important Definitions to Memorize

Firewall: Network security device that monitors and controls incoming/outgoing traffic based on predefined security rules.

IDS: System that detects malicious activity or policy violations and sends alerts — does NOT block traffic.

IPS: System that detects AND actively prevents/blocks malicious traffic in real-time (inline).

VPN: Technology that creates an encrypted, secure tunnel over a public network (internet) to connect remote users/sites.

HTTPS: HTTP protocol secured with SSL/TLS encryption. Operates on port 443. Uses CA-issued certificates.

DoS: Attack that overwhelms a server with traffic to make it unavailable to legitimate users. Single attacker.

DDoS: Same as DoS but uses multiple compromised machines (botnet) for a much larger-scale attack.

MITM: Attack where an adversary secretly intercepts communication between two parties — can eavesdrop and/or modify.

CIA Triad: Confidentiality (only authorized access) + Integrity (data not altered) + Availability (always accessible).

Zero Trust: Security model: 'Never trust, always verify' — no user/device trusted by default, even inside the network.

NGFW: Advanced firewall with DPI, IPS, app-awareness, SSL inspection, and threat intelligence — works at all OSI layers.

WPA2: Wi-Fi security protocol using AES-CCMP encryption. IEEE 802.11i standard (2004). Replaced WEP and WPA.

Best of luck in your ESE! 🎓

K.J. Somaiya College of Engineering | Network & Information Security | Chapter 4